Stoquify System Evaluation Risk Register

Date: 2026-08-28 Release posture: DEVELOPMENT_CONTINUES_PILOT_AND_PRODUCTION_FAIL_CLOSED
Decision: Production REJECTED; bounded blocker-closure work allowed

Rating scale

Severity:

- Critical: can invalidate tenant safety, financial truth, statutory scope, recovery, or production authority.
- High: can materially impair operations, user outcomes, evidence, or release confidence.
- Medium: important but bounded without invalidating the entire pilot.

Likelihood:

- High: currently observed or directly evidenced.
- Medium: plausible with incomplete controls or evidence.
- Low: unlikely under current bounded scope but still controlled.

Active risks

ID	Category	Risk	Severity	Likelihood	Evidence	Accountable owner	Required control	Exit criterion
R01	Release governance	A production or pilot claim is made from stale or mixed-candidate evidence	Critical	High	Dirty tree; master matrix bound to older candidate; B09 blocked	Release manager	One canonical current-truth register and immutable candidate	All active evidence is hash-bound to one clean commit
R02	Data integrity	Destructive migration drops data without exact-hash, backup, and restore approval	Critical	High	13 findings, 0 approvals	Database owner and independent checker	Per-finding disposition, backup, restore, reconciliation, expiry	Migration gate passes against approved target
R03	Database operations	Target history differs from expected migration history	Critical	High	Local database has one pending migration; production target absent	Database owner	Apply pending migration to disposable target; production-shaped rehearsal; direct status	Local, rehearsal, and target histories agree
R04	Tenant/commercial control	Module access uses onboarding intent or mixed observe/enforce behavior	Critical	High	requestedModules runtime derivation; hardEnforcementEnabled false; enforce calls exist	Platform security owner	Durable pilot entitlements and one coherent guard contract	Pilot access decisions come only from authoritative records

ID	Category	Risk	Severity	Likelihood	Evidence	Accountable owner	Required control	Exit criterion
R05	Authorization	Direct routes or actions bypass permission/module checks	Critical	High	79 missing-permission and 77 dashboard-only findings	Security and domain owners	Classify all surfaces; add permission/module negative tests and ratchet	Zero unresolved pilot-scope findings and zero new gaps
R06	Identity/session	Hard-coded module claims or unverified production IdP state misrepresent access	Critical	Medium	modulesEnabled hard-coded; production identity configuration unverified	IAM/security owner	Derive or remove claims; test revoked, stale, wrong-tenant, wrong-role sessions	Current candidate negative suite passes in production-shaped identity setup
R07	Secrets	Missing or reused secrets permit token forgery, disclosure, or delivery failure	Critical	High	Release secret gate 5/21, 16 blockers	Security platform owner	Purpose-specific managed secrets, valid encryption keys, URL, delivery policy	Release secret gate 21/21
R08	Credentials	Old or unclassified credentials remain usable	Critical	High	B07 has 31 blockers	Security owner and service owners	Inventory, classify, rotate, reject old versions, independently approve	Credential gate passes with no unresolved credential
R09	Statutory	Cameroon behavior is treated as legally valid without qualified approval	Critical	High	B06 4/12; signed artifact not verified	Compliance/legal owner	Qualified reviewer/checker, source digest recomputation, fixture decisions	Signed, verified decision for every included behavior
R10	Operations	Scheduled work silently stops, duplicates, or runs without accountable recovery	Critical	High	Scheduler evidence pending; B08 has 152 blockers	SRE/operations owner	Managed scheduler, single concurrency, lease proof, heartbeat, three windows	Operational gate passes and three successful windows are recorded
R11	Incident response	Alerts are not delivered, acknowledged, retried, escalated, or recovered	Critical	High	Alert transport and lifecycle fields are empty	SRE and security incident owners	End-to-end alert lifecycle test with owner SLO	Delivery, ack, retry, dead letter, recovery, escalation all proven
R12	Financial integrity	Payroll concurrency or failure creates duplicate or partial durable state	Critical	Medium	Payroll trust spine 5/6	Payroll engineering and controls owners	CAS, replay, idempotency conflict, and partial-commit tests	Static 6/6 and PostgreSQL certificate pass
R13	Financial integrity	Event gateway code and schema are not aligned on deployed targets	Critical	High	Business-event completion migration pending locally	Platform/event and database owners	Migration parity plus event/outbox integration and rollback tests	Event models and services run on candidate-bound target

ID	Category	Risk	Severity	Likelihood	Evidence	Accountable owner	Required control	Exit criterion
R14	Financial integrity	A domain bypasses the event/posting/source-link boundary	Critical	Medium	Strong kernels exist, but full adoption is not proven	Domain and accounting owners	Pilot workflow trace from source to event, posting, source link, audit, outbox	Every included economic event has complete trace and rollback proof
R15	Product/UX	User acts on the wrong result set because query, count, selection, and export scopes diverge	High	High	Fragmented table/query implementations	Frontend platform and domain data owners	Typed query ownership and explicit selection/export scope	Pilot routes reproduce one authorized query across UI and export
R16	Accessibility	Required workflows cannot be completed by keyboard or assistive technology	High	Medium	Shared semantics exist; authenticated proof absent	Accessibility and QA owners	Keyboard, focus, screen-reader, zoom, and state verification	No critical accessibility blocker in pilot tasks
R17	Localization	EN/FR behavior diverges or financial/date meaning changes by locale	High	Medium	Bilingual patterns are uneven	Localization and domain owners	Shared keys, locale-safe values, EN/FR route smoke	Equivalent task completion and evidence semantics in both locales
R18	Mobile/offline	Phone or intermittent-network behavior loses context or duplicates events	Critical	Medium	Horizontal-scroll dependence; offline production evidence not tested	POS/offline and frontend owners	Scope exclusion or replay/mobile proof with kill switch	Unsupported paths disabled or approved tests pass
R19	Provider boundary	Provider callbacks or settlements are treated as final truth without production evidence	Critical	Medium	PAY-02 blocked externally	Payments and security owners	Signature, replay, statement, match, suspense, settlement, and reconciliation proof	Approved provider scope passes production-shaped evidence gate
R20	Statutory hardware	Fiscal hardware behavior is implied without device and authority proof	Critical	Medium	POS hardware NOT_TESTED	Compliance and hardware owners	Explicit exclusion or validated device matrix and signed evidence	Unsupported hardware disabled or separately certified
R21	SaaS productization	Billing or package state directly changes access without durable internal truth	Critical	High	Package/subscription/billing workflow is missing	SaaS platform and security owners	Internal entitlement authority; billing as idempotent input	Package and entitlement lifecycle tests pass before commercialization
R22	AI safety	Agent output performs or authorizes a high-impact action	Critical	Medium	Production agent authority and behavioral qualification absent	AI safety and domain control owners	Read-only tools, prohibited actions, human approval, audit, kill switch	Zero unauthorized side effects in behavioral and pilot evidence

ID	Category	Risk	Severity	Likelihood	Evidence	Accountable owner	Required control	Exit criterion
R23	Data governance	Stale, incomplete, or unauthorized source data supports a trusted claim	High	Medium	Analytics/reporting partial; connector trust incomplete	Data governance and connector owners	Freshness, completeness, lineage, invalidation, redaction, owner SLA	Every pilot claim resolves to current trusted source evidence
R24	Performance/capacity	Production-like volume causes slow, memory-heavy, or inaccessible workflows	High	Medium	No current production trace or dataset benchmark	Performance and domain owners	Representative datasets, server-mode budgets, measured browser/service telemetry	Approved p75 budgets pass for pilot routes
R25	Cost	Model, telemetry, storage, provider, or support cost is unknown and unsustainable	Medium	Medium	No reliable cost ledger or unit baseline	Product operations and FinOps owners	Capture unit cost during rehearsal and pilot; set expansion threshold	Measured unit economics accepted before scope expansion
R26	Support/customer success	Pilot users encounter blocked workflows without owner or resolution path	High	High	Support and pilot owner assignments are unfilled	Pilot and support owners	Accepted coverage windows, runbooks, escalation, response SLO	Every pilot incident has accountable handling and evidence
R27	Scope	Broad feature work prevents blocker closure and stable freeze	High	High	Large repository and active UI work; B09 waiting for stable tree	Product and release managers	WIP limit two; explicit non-goals; feature freeze before B09	Candidate scope stable and no post-freeze runtime drift
R28	Evidence privacy	Secrets, PII, payroll, bank, or provider-sensitive data enters logs or reports	Critical	Medium	Redaction controls exist; production evidence flow unproven	Security/privacy owner	Redacted references only, evidence scans, least privilege, retention policy	Independent review finds no restricted value disclosure

Risk concentration

The top release-concentrating risks are R01-R14. They form one chain:

```
candidate ambiguity
  -> migration and access uncertainty
  -> secrets and credential uncertainty
  -> statutory and operations uncertainty
  -> inability to freeze
  -> inability to approve Gate 017
```

UX, accessibility, provider, AI, performance, cost, and customer-success risks remain material, but they should be handled inside the bounded pilot after the release-control spine is stable.

Mandatory stop conditions

Stop candidate advancement immediately if any of the following occurs:

1. Cross-tenant read, write, aggregate, export, or worker access.
2. RBAC or module bypass through wildcard, direct URL, direct action, API, report, export, or job.
3. Unbalanced, orphaned, mutable, or untraceable financial event.
4. Payroll duplicate, stale compare-and-set acceptance, or partial commit.
5. Unapproved destructive migration or failed restore.
6. Secret, credential, PII, employee, bank, or provider-sensitive value in evidence.
7. Unsigned or out-of-scope statutory behavior.
8. Scheduler duplication, stale heartbeat, unacknowledged alert, or failed rollback.
9. Candidate/evidence hash mismatch or post-freeze drift.
10. AI attempts a prohibited high-impact action.

Risk acceptance rules

- Critical risks cannot be accepted through undocumented judgment.
- Legal, tax, payroll, social-security, authority-submission, and fiscal-hardware risks require qualified human review.
- Security, migration, release, and operational approvals require segregation of duties.
- Every temporary acceptance must have owner, scope, reason, evidence, expiry, monitoring, and rollback.
- A passing technical test does not override missing external authority.
- A ready repository gate does not prove a production provider setting.
- Source hashes prove identity, not legal correctness.
- Isolated PostgreSQL evidence proves only its declared environment and invariant.

Residual risk after the target state

Even after Phase 2B entry, residual risk remains:

- Pilot evidence does not authorize Phase 3 production.
- A narrow Cameroon scope does not validate other countries.
- Cash-only POS does not validate every tender or provider.
- Internal payroll does not validate every declaration or payment channel.
- Pilot load does not prove broad enterprise capacity.
- One entitlement cohort does not complete commercial packaging and billing.
- Read-only agent qualification does not authorize autonomous actions.

Those risks are acceptable only because the pilot scope, cohort, controls, observation, kill switch, and rollback are explicit.